

CVEs más relevantes de la semana

Del 24/03/2026 al 31/03/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-33407

Descripción: Wallos is an open-source, self-hostable personal subscription tracker. Prior to version 4.7.0, Wallos endpoints/logos/search.php accepts HTTP_PROXY and HTTPS_PROXY environment variables without validation, enabling SSRF via proxy hijacking. The server performs DNS resolution on user-supplied search terms, which can be controlled by attackers to trigger outbound requests to arbitrary domains. Th...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33409

Descripción: Parse Server is an open source backend that can be deployed to any infrastructure that can run Node.js. Prior to versions 8.6.52 and 9.6.0-alpha.41, an authentication bypass vulnerability allows an attacker to log in as any user who has linked a third-party authentication provider, without knowing the user's credentials. The attacker only needs to know the user's provider ID to gain full access...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33768

Descripción: Astro is a web framework. Prior to version 10.0.2, the @astrojs/vercel serverless entrypoint reads the x-astro-path header and x_astro_path query parameter to rewrite the internal request path, with no authentication whatsoever. On deployments without Edge Middleware, this lets anyone bypass Vercel's platform-level path restrictions entirely. The override preserves the original HTTP method and ...

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Tipo: CWE-441

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33511

Descripción: pyLoad is a free and open-source download manager written in Python. From version 0.4.20 to before version 0.5.0b3.dev97, the local_check decorator in pyLoad's ClickNLoad feature can be bypassed by any remote attacker through HTTP Host header spoofing. This allows unauthenticated remote users to access localhost-restricted endpoints, enabling them to inject arbitrary downloads, write files to t...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-24157

Descripción: NVIDIA NeMo Framework contains a vulnerability in checkpoint loading where an attacker could cause remote code execution. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, information disclosure and data tampering.

CVSS: 7.8 (HIGH)

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-24159

Descripción: NVIDIA NeMo Framework contains a vulnerability where an attacker may cause remote code execution. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, information disclosure and data tampering.

CVSS: 7.8 (HIGH)

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2025-59706

Descripción: In N2W before 4.3.2 and 4.4.0 before 4.4.1, improper validation of API request parameters enables remote code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2025-59707

Descripción: In N2W before 4.3.2 and 4.4.x before 4.4.1, there is potential remote code execution and account credentials theft because of a spoofing vulnerability.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2026-26831

Descripción: textract through 2.5.0 is vulnerable to OS Command Injection via the file path parameter in multiple extractors. When processing files with malicious filenames, the filePath is passed directly to `child_process.exec()` in `lib/extractors/doc.js`, `rtf.js`, `dxf.js`, `images.js`, and `lib/util.js` with inadequate sanitization

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2026-26833

Descripción: thumblr through 1.1.2 allows OS command injection via the input, output, time, or size parameter in the thumbnail() function because user input is concatenated into a shell command string passed to `child_process.exec()` without proper sanitization or escaping.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2026-33749

Descripción: n8n is an open source workflow automation platform. Prior to versions 1.123.27, 2.13.3, and 2.14.1, an authenticated user with permission to create or modify workflows could craft a workflow that produces an HTML binary data object without a filename. The `/rest/binary-data` endpoint served such responses inline on the n8n origin without `Content-Disposition` or `Content-Security-Policy` header...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2025-14917

Descripción: IBM WebSphere Application Server - Liberty 17.0.0.3 through 26.0.0.3 IBM WebSphere Application Server Liberty could provide weaker than expected security when administering security settings.

CVSS: 6.7 (MEDIUM)

Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1393

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2026-30975

Descripción: Sonarr is a PVR for Usenet and BitTorrent users. Versions prior to 4.0.16.2942 have an authentication bypass that affected users that had disabled authentication for local addresses (Authentication Required set to: 'Disabled for Local Addresses') without a reverse proxy running in front of Sonarr that didn't not pass through the invalid header. Patches are available in version 4.0.16.2942 in th...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2026-33183

Descripción: Saloon is a PHP library that gives users tools to build API integrations and SDKs. Prior to version 4.0.0, fixture names were used to build file paths under the configured fixture directory without validation. A name containing path segments (e.g. ../traversal or ../../etc/passwd) resulted in a path outside that directory. When the application read a fixture (e.g. for mocking) or wrote one (e.g...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2026-33942

Descripción: Saloon is a PHP library that gives users tools to build API integrations and SDKs. Versions prior to 4.0.0 used PHP's unserialize() in AccessTokenAuthenticator::unserialize() to restore OAuth token state from cache or storage, with allowed_classes => true. An attacker who can control the serialized string (e.g. by overwriting a cached token file or via another injection) can supply a serialized...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2026-4484

Descripción: The Masteriyo LMS plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 2.1.6. This is due to the plugin allowing a user to update the user role through the 'InstructorsController::prepare_object_for_database' function. This makes it possible for authenticated attackers, with Student-level access and above, to elevate their privileges to that of an adm...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25183

Descripción: Shipping System CMS 1.0 contains an SQL injection vulnerability that allows unauthenticated attackers to bypass authentication by injecting SQL code through the username parameter. Attackers can submit malicious SQL payloads using boolean-based blind techniques in POST requests to the admin login endpoint to authenticate without valid credentials.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25185

Descripción: Wecodex Restaurant CMS 1.0 contains an SQL injection vulnerability that allows unauthenticated attackers to manipulate database queries by injecting SQL code through the username parameter. Attackers can send POST requests to the login endpoint with malicious SQL payloads using boolean-based blind or time-based blind techniques to extract sensitive database information.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25195

Descripción: Wecodex Hotel CMS 1.0 contains an SQL injection vulnerability in the admin login functionality that allows unauthenticated attackers to bypass authentication by injecting SQL code. Attackers can submit malicious SQL payloads through the username parameter in POST requests to index.php with action=processlogin to extract sensitive database information or gain unauthorized administrative access.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25201

Descripción: School Management System CMS 1.0 contains an SQL injection vulnerability in the admin login functionality that allows attackers to bypass authentication by injecting SQL code through the username parameter. Attackers can submit malicious payloads using boolean-based blind SQL injection techniques to the processlogin endpoint to authenticate as administrator without valid credentials.

CVSS: 7.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25204

Descripción: Library CMS 1.0 contains an SQL injection vulnerability that allows unauthenticated attackers to bypass authentication by injecting SQL code through the username parameter. Attackers can send POST requests to the admin login endpoint with boolean-based blind SQL injection payloads in the username field to manipulate database queries and gain unauthorized access.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55267

Descripción: HCL Aftermarket DPC is affected by Unrestricted File Upload vulnerability, allows attacker to upload and execute malicious scripts, gaining full control over the server.

CVSS: 5.7 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:N/I:H/A:N

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55269

Descripción: HCL Aftermarket DPC is affected by Weak Password Policy vulnerability, which makes it easier for attackers to guess weak passwords or use brute-force techniques to gain unauthorized access to user accounts.

CVSS: 4.2 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:L

Tipo: CWE-521

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55270

Descripción: HCL Aftermarket DPC is affected by Improper Input Validation which allows an attacker to inject executable code and can carry out attacks such as XSS, SQL Injection, Command Injection etc.

CVSS: 3.5 (LOW)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:N/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55261

Descripción: HCL Aftermarket DPC is affected by Missing Functional Level Access Control which will allow attacker to escalate his privileges and may compromise the application and may steal and manipulate the data.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2026-27815

Descripción: EVerest is an EV charging software stack. Prior to versions to 2026.02.0, ISO15118_chargerImpl::handle_session_setup copies a variable-length payment_options list into a fixed-size array of length 2 without bounds checking. With schema validation disabled by default, oversized MQTT Cmd payloads can trigger out-of-bounds writes and corrupt adjacent EVSE state or crash the process. Version 2026.0...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2026-27816

Descripción: EVerest is an EV charging software stack. Prior to versions to 2026.02.0, ISO15118_chargerImpl::handle_update_energy_transfer_modes copies a variable-length list into a fixed-size array of length 6 without bounds checking. With schema validation disabled by default, oversized MQTT Cmd payloads can trigger out-of-bounds writes and corrupt adjacent EVSE state or crash the process. Version 2026.02...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2026-33640

Descripción: Outline is a service that allows for collaborative documentation. Outline implements an Email OTP login flow for users not associated with an Identity Provider. Starting in version 0.86.0 and prior to version 1.6.0, Outline does not invalidate OTP codes based on amount or frequency of invalid submissions, rather it relies on the rate limiter to restrict attempts. Consequently, identified bypass...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2026-33770

Descripción: WWBN AVideo is an open source video platform. In versions up to and including 26.0, the `fixCleanTitle()` static method in `objects/category.php` constructs a SQL SELECT query by directly interpolating both `\$clean\_title` and `\$id` into the query string without using prepared statements or parameterized queries. An attacker who can trigger category creation or renaming with a crafted title valu...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-27



CVE-2016-20049

Descripción: JAD 1.5.8e-1kali1 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by supplying oversized input that exceeds buffer boundaries. Attackers can craft malicious input strings exceeding 8150 bytes to overflow the stack, overwrite return addresses, and execute shellcode in the application context.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2017-20225

Descripción: TiEmu 2.08 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by exploiting inadequate boundary checks on user-supplied input. Attackers can trigger the overflow through command-line arguments passed to the application, leveraging ROP gadgets to bypass protections and execute shellcode in the application context.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2017-20227

Descripción: JAD Java Decompiler 1.5.8e-1kali1 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by supplying overly long input that exceeds buffer boundaries. Attackers can craft malicious input passed to the jad command to overflow the stack and execute a return-oriented programming chain that spawns a shell.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2017-20229

Descripción: MAWK 1.3.3-17 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by exploiting inadequate boundary checks on user-supplied input. Attackers can craft malicious input that overflows the stack buffer and execute a return-oriented programming chain to spawn a shell with application privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2018-25220

Descripción: Bochs 2.6-5 contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by supplying an oversized input string to the application. Attackers can craft a malicious payload with 1200 bytes of padding followed by a return-oriented programming chain to overwrite the instruction pointer and execute shell commands with application privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2018-25221

Descripción: EChat Server 3.1 contains a buffer overflow vulnerability in the chat.ghp endpoint that allows remote attackers to execute arbitrary code by supplying an oversized username parameter. Attackers can send a GET request to chat.ghp with a malicious username value containing shellcode and ROP gadgets to achieve code execution in the application context.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2018-25223

Descripción: Crashmail 1.6 contains a stack-based buffer overflow vulnerability that allows remote attackers to execute arbitrary code by sending malicious input to the application. Attackers can craft payloads with ROP chains to achieve code execution in the application context, with failed attempts potentially causing denial of service.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2026-5020

Descripción: A vulnerability was detected in Totolink A3600R 4.1.2cu.5182_B20201102. Affected by this issue is the function setNoticeCfg of the file /cgi-bin/cstecgi.cgi of the component Parameter Handler. The manipulation of the argument NoticeUrl results in command injection. The attack may be launched remotely. The exploit is now public and may be used.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5030

Descripción: A vulnerability has been found in Totolink NR1800X 9.1.0u.6279_B20210910. This issue affects the function NTPSyncWithHost of the file /cgi-bin/cstecgi.cgi of the component Telnet Service. The manipulation of the argument host_time leads to command injection. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5033

Descripción: A vulnerability was detected in code-projects Accounting System 1.0. Affected by this vulnerability is an unknown functionality of the file /view_costumer.php of the component Parameter Handler. The manipulation of the argument cos_id results in sql injection. The attack may be performed from remote. The exploit is now public and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5034

Descripción: A flaw has been found in code-projects Accounting System 1.0. Affected by this issue is some unknown functionality of the file /edit_costumer.php of the component Parameter Handler. This manipulation of the argument cos_id causes sql injection. It is possible to initiate the attack remotely. The exploit has been published and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5035

Descripción: A vulnerability has been found in code-projects Accounting System 1.0. This affects an unknown part of the file /view_work.php of the component Parameter Handler. Such manipulation of the argument en_id leads to sql injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32922

Descripción: OpenClaw before 2026.3.11 contains a privilege escalation vulnerability in device.token.rotate that allows callers with operator.pairing scope to mint tokens with broader scopes by failing to constrain newly minted scopes to the caller's current scope set. Attackers can obtain operator.admin tokens for paired devices and achieve remote code execution on connected nodes via system.run or gain un...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-266

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32924

Descripción: OpenClaw before 2026.3.12 contains an authorization bypass vulnerability where Feishu reaction events with omitted chat_type are misclassified as p2p conversations instead of group chats. Attackers can exploit this misclassification to bypass groupAllowFrom and requireMention protections in group chat reaction-derived events.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32973

Descripción: OpenClaw before 2026.3.11 contains an exec allowlist bypass vulnerability where matchesExecAllowlistPattern improperly normalizes patterns with lowercasing and glob matching that overmatches on POSIX paths. Attackers can exploit the ? wildcard matching across path segments to execute commands or paths not intended by operators.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-625

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32974

Descripción: OpenClaw before 2026.3.12 contains an authentication bypass vulnerability in Feishu webhook mode when only verificationToken is configured without encryptKey, allowing acceptance of forged events. Unauthenticated network attackers can inject forged Feishu events and trigger downstream tool execution by reaching the webhook endpoint.

CVSS: 8.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32975

Descripción: OpenClaw before 2026.3.12 contains a weak authorization vulnerability in Zalouser allowlist mode that matches mutable group display names instead of stable group identifiers. Attackers can create groups with identical names to allowlisted groups to bypass channel authorization and route messages from unintended groups to the agent.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-807

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32987

Descripción: OpenClaw before 2026.3.13 allows bootstrap setup codes to be replayed during device pairing verification in `src/infra/device-bootstrap.ts`. Attackers can verify a valid bootstrap code multiple times before approval to escalate pending pairing scopes, including privilege escalation to `operator.admin`.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-294

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-4257

Descripción: The Contact Form by Supsystic plugin for WordPress is vulnerable to Server-Side Template Injection (SSTI) leading to Remote Code Execution (RCE) in all versions up to, and including, 1.7.36. This is due to the plugin using the Twig `Twig\_Loader\_String` template engine without sandboxing, combined with the `cfsPreFill` prefill functionality that allows unauthenticated users to inject arbitrary T...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-30



CVE-2026-3300

Descripción: The Everest Forms Pro plugin for WordPress is vulnerable to Remote Code Execution via PHP Code Injection in all versions up to, and including, 1.9.12. This is due to the Calculation Addon's process_filter() function concatenating user-submitted form field values into a PHP code string without proper escaping before passing it to eval(). The sanitize_text_field() function applied to input does n...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-32917

Descripción: OpenClaw before 2026.3.13 contains a remote command injection vulnerability in the iMessage attachment staging flow that allows attackers to execute arbitrary commands on configured remote hosts. The vulnerability exists because unsanitized remote attachment paths containing shell metacharacters are passed directly to the SCP remote operand without validation, enabling command execution when re...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-32920

Descripción: OpenClaw before 2026.3.12 automatically discovers and loads plugins from .OpenClaw/extensions/ without explicit trust verification, allowing arbitrary code execution. Attackers can execute malicious code by including crafted workspace plugins in cloned repositories that execute when users run OpenClaw from the directory.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-829

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34505

Descripción: OpenClaw before 2026.3.12 applies rate limiting only after successful webhook authentication, allowing attackers to bypass rate limits and brute-force webhook secrets. Attackers can submit repeated authentication requests with invalid secrets without triggering rate limit responses, enabling systematic secret guessing and subsequent forged webhook submission.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-33576

Descripción: OpenClaw before 2026.3.28 downloads and stores inbound media from Zalo channels before validating sender authorization. Unauthorized senders can force network fetches and disk writes to the media store by sending messages that are subsequently rejected.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-33577

Descripción: OpenClaw before 2026.3.28 contains an insufficient scope validation vulnerability in the node pairing approval path that allows low-privilege operators to approve nodes with broader scopes. Attackers can exploit missing callerScopes validation in node-pairing.ts to extend privileges onto paired nodes beyond their authorization level.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-33578

Descripción: OpenClaw before 2026.3.28 contains a sender policy bypass vulnerability in the Google Chat and Zalouser extensions where route-level group allowlist policies silently downgrade to open policy. Attackers can exploit this policy resolution flaw to bypass sender restrictions and interact with bots despite configured allowlist restrictions.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-33579

Descripción: OpenClaw before 2026.3.28 contains a privilege escalation vulnerability in the /pair approve command path that fails to forward caller scopes into the core approval check. A caller with pairing privileges but without admin privileges can approve pending device requests asking for broader scopes including admin access by exploiting the missing scope validation in extensions/device-pair/index.ts ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-33580

Descripción: OpenClaw before 2026.3.28 contains a missing rate limiting vulnerability in the Nextcloud Talk webhook authentication that allows attackers to brute-force weak shared secrets. Attackers who can reach the webhook endpoint can exploit this to forge inbound webhook events by repeatedly attempting authentication without throttling.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-03-31



Resumen del Reporte

CVEs analizados: 57

Promedio CVSS: 8.77

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☺

